

פרק 6 – אבטחת הרשת המקומית (LAN Security)

11 שעות עיוני + 2 מעשי · שבועות 17-19

מטרות: התקפות שכבה 2 · port security · STP/VLAN · DHCP/ARP · storm control · SPAN · NAC · VoIP/SAN ·
בבגרות: VLAN hopping, BPDU Guard, Evil Twin, root→port security, DTP→MAC overflow, bridge

לפני שמתחילים – מה קורה ב"שכבה 2"? (למי שאין רקע)

עד עכשיו דיברנו על כתובות IP (שכבה 3). אבל בתוך רשת מקומית, המכשירים מדברים ביניהם דרך **מתג** לפי **כתובות MAC** (שכבה 2). כמה מושגים: **מתג** (Switch) – מחבר את כל המחשבים ברשת המקומית. הוא לומד איזו כתובת MAC נמצאת באיזה פורט, ושומר זאת ב**טבלת** MAC. VLAN – "רשת וירטואלית". מפצל מתג פיזי אחד לכמה רשתות נפרדות ומבודדות (למשל VLAN למחלקת כספים ו-VLAN לאורחים) בלי לקנות עוד מתגים. Trunk – קישור בין מתגים שנושא כמה VLANים יחד. Broadcast – הודעה שנשלחת ל**ל**כל המכשירים ברשת בבת אחת ("שידור"). STP – פרוטוקול שמונע "לולאות" בין מתגים (נסביר בהמשך למה לולאה מפילה רשת). **למה זה קריטי לאבטחה?** אם תוקף כבר מחובר לרשת המקומית (חיבר מחשב לשקע, פרץ ל-Wi-Fi), הוא פועל בשכבה 2 – תחתם לכל ההגנות של שכבה 3 (חומת אש, IP) לכן צריך להגן גם כאן.

6.1 למה שכבה 2 היא "הבטן הרכה"

כל מנגנוני האבטחה שלמדנו עד כה עובדים בשכבה 3 ומעלה (ACL, IPS, VPN) אבל אם התוקף כבר **ברשת המקומית** – חיבר לפטופ לשקע, פרץ ל-Wi-Fi, או השתלט על מחשב עובד – הוא פועל בשכבה 2, מתחת לכל ההגנות האלה. עיקרון קריטי: **מודל OSI הוא שרשרת – אם שכבה 2 נפרצת, כל השכבות מעליה נפגעות**. מתג "בוטח" בכל מה שמחובר אליו כברירת מחדל, וזו הבעיה.

סיפור מהחיים: השקע בחדר ישיבות

בבדיקת חדירה נפוצה, הבודק מגיע כ"טכניקאי", מבקש להמתין בחדר ישיבות, ומחבר מכשיר קטן (Rasp-berry Pi) לשקע רשת מתחת לשולחן. המכשיר מבצע ARP spoofing ומקליט תעבורה, או מריץ Responder hashes של סיסמאות. הוא יוצא אחרי חצי שעה, והמכשיר ממשיך לשדר דרך LTE. אף חומת אש לא ראתה כלום – הכול קרה בשכבה 2, בתוך ה-VLAN. ההגנות בפרק הזה (port security, DHCP snooping, DAI, 802.1X) הן בדיוק מה שהיה עוצר אותו.

6.2 מפת ההתקפות וההגנות בשכבה 2

התקפה	מה מנצלת	הגנה עיקרית
MAC table overflow (CAM flooding)	גודל מוגבל של טבלת ה-MAC	Port Security
VLAN hopping (switch spoofing)	DTP – משא-ומתן trunk אוטומטי	switchport mode access
VLAN hopping (double tagging)	Native VLAN	Native VLAN ייעודי ולא בשימוש
STP manipulation	בחירת root bridge לפי priority	BPDU Guard, Root Guard
DHCP starvation / spoofing (rogue DHCP)	אין אימות ל-DHCP	DHCP Snooping
ARP spoofing / poisoning (MITM)	חסר אימות ARP	Dynamic ARP Inspection (DAI) (מסתמך על DHCP snooping)
MAC/IP spoofing	אין קשירת כתובת לפורט	IP Source Guard
CDP reconnaissance	CDP משדר דגם, IP, IOS	no cdp enable על פורטי קצה

Port Security-1 6.3 MAC Table Overflow

מתג לומד כתובות MAC ורושם אותן בטבלת CAM (Content Addressable Memory) יחד עם הפורט. הטבלה מוגבלת (למשל 8,000 רשומות). כלי כמו macof מציף את המתג באלפי כתובות MAC מזויפות בשנייה; הטבלה מתמלאת, והמתג עובר ל-fail-open - מתחיל לשדר כל מסגרת לכל הפורטים (כמו hub). עכשיו התוקף רואה את תעבורת כולם. זהו "MAC flooding".

Port Security – ההגנה

```
S1(config)# interface f0/1
S1(config-if)# switchport mode access ! חובה - port security לא עובד על trunk דינמי
S1(config-if)# switchport port-security
S1(config-if)# switchport port-security maximum 2 IP (מחשב + טלפון)
S1(config-if)# switchport port-security mac-address sticky ! לומד את הכתובת ושומר בקונפיג
S1(config-if)# switchport port-security violation shutdown
S1(config-if)# switchport port-security aging time 60
! וריפיקציה
S1# show port-security
S1# show port-security interface f0/1
S1# show port-security address
```

שלושה מצבי הפרה (violation)

מונה	התראה	מה קורה בהפרה	מצב
לא	לא	מפיל מסגרות מ-MAC לא מוכרות; הפורט נשאר up	protect
כן	כן (syslog/SNMP)	מפיל מסגרות; הפורט up	restrict
כן	כן	הפורט עובר ל-err-disabled - מושב ל-gmri	shutdown (ברירת מחדל)

שאלת תלמיד: "הפורט נכבה. (err-disabled) איך מחזירים אותו?"

ידינית: shutdown ואז no shutdown על הממשק. אוטומטית אחרי זמן: errdisable recovery
show interfaces status err-disabled. הערה: sticky נדבק ל-running-config - אל תשכחו
write אחרת הכתובת תיעלם ב-reload.

טעות נפוצה

מגדירים port security ושוכחים switchport mode access. אם הפורט במצב dynamic, port security לא נכנס לתוקף כראוי. וגם: maximum 1 עם טלפון IP + מחשב מאחוריו ⇒ הפרות מיידיות; להגדיר maximum 2 או להשתמש ב-voice VLAN.

VLAN 6.4 – והתקפת VLAN Hopping

VLAN מפצל מתג פיזי אחד לכמה רשתות לוגיות מבודדות. מעבר בין VLANים דורש ניתוב (router / L3 switch). קישור בין מתגים שנושא כמה VLANים נקרא trunk ומשתמש בתיוג 802.1Q (מוסיף תג של 4 בתים עם מספר ה-VLAN לכל מסגרת). Native VLAN - ה-VLAN היחיד שעובר ב-trunk בלי תג (ברירת מחדל. VLAN 1).

התקפה א': Switch Spoofing (ניצול DTP)

DTP (Dynamic Trunking Protocol) מאפשר לשני מתגים "לסכם" אוטומטית אם הקישור ביניהם יהיה trunk. הבעיה: פורט קצה במצב ברירת מחדל (dynamic desirable / dynamic auto) יסכים להפוך ל-trunk גם

מול מחשב של תוקף שמתחזה למתג ושולח DTP. ברגע שהקישור trunk – התוקף מקבל גישה לכל ה-VLANים. זו התשובה בבגרות: "השבתת DTP מונעת". VLAN hopping

התקפה ב': Double Tagging

התוקף (ב-VLAN של ה-native שולח מסגרת עם שני תגים: החיצוני = native VLAN (המתג הראשון מסיר אותו), הפנימי = ה-VLAN של הקורבן. המתג השני רואה את התג הפנימי ומעביר ל-VLAN הקורבן. חד-כיווני, אך מסוכן. הגנה: native VLAN שאינו בשימוש ואינו VLAN 1.

ההגנה על פורטים

```
! פורט קצה (למחשב) - מפורש access, כיבוי DTP
S1(config)# interface range f0/1 - 20
S1(config-if-range)# switchport mode access
S1(config-if-range)# switchport access vlan 10
S1(config-if-range)# switchport nonegotiate DTP לא לשלוח !
S1(config-if-range)# spanning-tree portfast
S1(config-if-range)# spanning-tree bpduguard enable
! פורט trunk, native מפורש, ייעודי
S1(config)# interface g0/1
S1(config-if)# switchport mode trunk
S1(config-if)# switchport nonegotiate
S1(config-if)# switchport trunk native vlan 999 "VLAN שחור", לא בשימוש
S1(config-if)# switchport trunk allowed vlan 10,20,30 ! רק מה שצריך
! פורטים לא בשימוש - לכבות ולשים ב-VLAN מבודד
S1(config)# interface range f0/21 - 24
S1(config-if-range)# switchport access vlan 999
S1(config-if-range)# shutdown
```

STP 6.5 והתקפות עליו

STP (Spanning Tree Protocol, 802.1D) מונע **לולאות** בשכבה 2. למה לולאות מסוכנות? למסגרת שכבה 2 אין TTL (בניגוד ל-IP) אם יש לולאה פיזית בין מתגים, מסגרת broadcast תסתובב לנצח, תשוכפל בכל סיבוב, ותייצר broadcast storm שמשתק את הרשת תוך שניות. STP חוסם באופן לוגי פורטים כדי להשאיר מסלול יחיד, ופותח אותם אם קישור נופל.

בבגרות (שאלה 13)

"פרוטוקול STP מונע לולאות מיתוג במודל ה-OSI בשכבה מספר ____ - 2". (Data Link) הפעולה של מניעת הלולאות נעשית על ידי ____ - Port blocking (חסימת יציאות).

איך נבחר ה-Root Bridge (נשאל בבגרות!)

המתג עם Bridge ID הנמוך ביותר הופך ל-Root. Bridge ID = Priority (2 = root) + MAC address. ברירת מחדל priority = 32768. אם ה-priority שווה - מכריע ה-MAC הנמוך ביותר.

בבגרות (שאלה 13)

4 מתגים, priority ברירת מחדל זהה. MACים: SW1=0C:0E:15:22:05:97, SW2=0C:E0:38:00:36:75, SW3=0C:E0:18:A1:B3:19, SW4=0C:0E:15:1A:3C:9D. מי ה-root? משווים בית-בית: SW1 ו-SW4 מתחילים ב-0C:0E:15, השאר ב-0C:E0. הבית הרביעי: SW1=22, SW4=1A. 22 > 1A ⇒ SW4 הוא ה-root bridge. הסיבה: "כי כתובת ה-MAC שלו היא הנמוכה ביותר" (וה-priority זהה).

OSPF DR/BDR - רקע לשאלה 2 (שכבה 3, אך נשאל)

בבחירת DR/BDR ב-OSPF: קודם priority הגבוה ביותר, ואם שווה - Router-ID הגבוה ביותר. בשאלת הבגרות. הבגרות. R1(pri 2, RID 1.1.1.1), R2(pri 1), R3(pri 2, RID 3.3.3.3), R4(pri 1). priority 2: R3

R3 = DR $\Rightarrow$ (RID 3.3.3.3) > R1 (RID 1.1.1.1) - R1 הוא הגבוה מבין הנותרים בעלי priority 2. R3 = DR, R1 = BDR תשובה: priority 2, R1 הוא הבא; אבל אחרי DR משווים את השאר (שימו לב: ההיגיון הפוך מ-STP - שם נמוך מנצח, כאן גבוה).

הגנות STP

מנגנון	מה עושה	איפה
PortFast	פורט קצה עובר מיד ל-forwarding (לא מחכה 30 שניות)	פורטי access למחשבים
BPDU Guard	אם פורט PortFast מקבל BPDU (כלומר חובר אליו מתג/תוקף) - err-disable מידי	פורטי קצה
Root Guard	מונע ממתג בפורט זה להפוך ל-root (אם ישלח BPDU עדיף - הפורט נחסם)	פורטים למתגי גישה מתחת
Loop Guard	מגן מלולאה כשפורט מפסיק לקבל BPDU	קישורים redundant

```
! פר-ממשק
S1(config-if)# spanning-tree portfast
S1(config-if)# spanning-tree bpduguard enable
! גלובלי - על כל פורטי PortFast (זו התשובה בבגרות שאלה 7)
S1(config)# spanning-tree portfast default
S1(config)# spanning-tree portfast bpduguard default
! שהמתג שלנו יהיה root בוודאות
S1(config)# spanning-tree vlan 10 root primary 24576 priority ל-
S1(config)# spanning-tree vlan 10 priority של 4096 4096 חייב כפולה
S1# show spanning-tree
```

DHCP Snooping, Spoofing - 6.6 DHCP

DHCP starvation: תוקף מבקש את כל הכתובות ב-pool (עם MACים מזויפים) - משתמשים אמיתיים לא מקבלים כתובת. DHCP spoofing (rogue server) (DoS): התוקף מקים שרת DHCP משלו שעונה מהר יותר, ומחלק לקורבנות default gateway = **הכתובת שלו** ו-DNS **שלו** $\Rightarrow$ MITM על כל התעבורה.

DHCP Snooping - ההגנה

המתג מסמן פורטים כ-trusted (לכיוון שרת ה-DHCP הליגיטימי) / uplink או untrusted (פורטי קצה, ברירת מחדל). הודעות שרת (OFFER, ACK) מפורט untrusted - נחסמות. המתג בונה DHCP Snooping Binding Table (MAC $\leftrightarrow$ IP $\leftrightarrow$ פורט) $\leftrightarrow$ VLAN - בסיס ל-DAI ו-IP Source Guard.

```
S1(config)# ip dhcp snooping
S1(config)# ip dhcp snooping vlan 10,20
! לכיוון שרת DHCP הליגיטימי
S1(config)# interface g0/1
S1(config-if)# ip dhcp snooping trust
! פורטי קצה 20 - f0/1
S1(config-if-range)# ip dhcp snooping limit rate 6 starvation נגד !
S1# show ip dhcp snooping binding
```

Dynamic ARP Inspection (DAI) - 6.7 ARP Spoofing

ARP ממפה IP ל-MAC, וחסר כל אימות: כל מחשב יכול לשלוח "Gratuitous ARP" שאומר "אני ה-gateway" - והקורבנות יעדכנו את הטבלה שלהם ויתחילו לשלוח את התעבורה לתוקף. DAI (MITM) בודק כל הודעת ARP מול טבלת ה-DHCP Snooping: אם ה-MAC $\leftrightarrow$ IP לא תואם לרשומה - ההודעה נזרקת.

```
S1(config)# ip arp inspection vlan 10,20
S1(config)# interface g0/1
S1(config-if)# ip arp inspection trust ! uplink מהימן
! לפורטים סטטיים בלי DHCP - מגדירים ACL של ARP ידני
S1(config)# arp access-list STATIC-HOSTS
S1(config-arp-nacl)# permit ip host 10.0.0.5 mac host aaaa.bbbb.cccc
S1# show ip arp inspection
```

המשלים: IP Source Guard - מוודא שכתובת ה-IP במסגרת תואמת לפורט לפי טבלת ה-snooping (נגד IP spoofing).

6.8 Storm Control

מגביל את אחוז התעבורה מסוג broadcast / multicast / unknown-unicast על פורט; אם עוברים סף - המתג מפיל את העודף (ומתריע). מגן מ-broadcast storms (גם מלולאה וגם מתקלה/התקפה). התכנית מציינת "Storm Control (SC)".

```
S1(config-if)# storm-control broadcast level 5.00 ! מעל 5% מרוחב הפס - הגבל
S1(config-if)# storm-control multicast level pps 1k
S1(config-if)# storm-control action shutdown trap ! או
S1# show storm-control
```

6.9 SPAN - שיקוף פורטים (הבסיס ל-IDS)

SPAN (Switched Port Analyzer, "port mirroring") מעתיק את כל התעבורה מפורט/VLAN מקור לפורט יעד - שאליו מחובר Wireshark או IDS. זה החיבור לפרק "IDS: 5 מחוץ לנתיב" מקבל את התעבורה דווקא דרך SPAN. RSPAN - שיקוף בין מתגים דרך VLAN ייעודי; ERSPAN - מעל IP (GRE).

```
S1(config)# monitor session 1 source interface f0/1 - 10 both
S1(config)# monitor session 1 destination interface f0/24 ! כאן ה-Wireshark/IDS
S1# show monitor session 1
```

שאלת תלמיד: "אם ה-IDS רק מקבל עותק דרך SPAN, למה שלא נחבר אותו inline ונחסום?"

כי אז הוא IPS, לא IDS - והוא מוסיף השהיה ונקודת כשל בנתיב. SPAN מאפשר לנטר בלי לגעת בזרימה: הפורט המשקף יכול אפילו ליפול בלי להשפיע על הרשת. זה בדיוק ה-trade-off מפרק 5.

6.10 NAC ו-802.1X

NAC (Network Access Control) - "בקרת בריאות": לפני שמחשב מקבל גישה מלאה, בודקים שהוא עומד בתנאים (אנטי-וירוס מעודכן, patch, אין תוכנות אסורות). מחשב שנכשל מועבר ל-"VLAN הסגר" (quarantine) לתיקון. הבסיס הטכני: 802.1X (פרק 3) - המתג/AP חוסם את הפורט עד אימות מול RADIUS. שילוב: 802.1X מאמת מי, NAC בודק באיזה מצב המכשיר.

6.11 מערכות קצה: IronPort, CSA, ומיילים/אתרים

- Cisco IronPort - משפחת מכשירים לאבטחת תוכן בקצה: ESA (Email Security Appliance) - סינון spam, phishing, ווירוסים במייל; WSA (Web Security Appliance) - proxy שמסנן אתרים זדוניים, URL filtering, בדיקת הורדות. סיסקו רכשה את IronPort ב-2007.
- CSA (Cisco Security Agent) - HIPS על התחנה (פרק 5).
- היום התחום נקרא CASB / Secure Web / Secure Email / SWG, ולרוב בענן. (Cisco Umbrella).

6.12 אבטחת VoIP ו-SAN

VoIP (טלפוניה על IP)

איומים: האזנה לשיחות (sniffing), toll fraud (שימוש לא מורשה בקווים לחיוב יקר), התחזות caller-ID (spoofing על ה-spam), SPIT (PBX קולי), הגנות: Voice VLAN **נפרד** (הפרדה מתעבורת הנתונים), DoS (בידוד לוגי), אימות TLS/SIP-TLS (ליתות), אימות מכשירי טלפון, ACL בין voice ל-data.

```
S1(config-if)# switchport access vlan 10 ! נתונים
S1(config-if)# switchport voice vlan 20 ! קול - מתייג בנפרד
```

SAN (רשת אחסון)

SAN מחברת שרתים לאחסון בלוקים (Fibre Channel / iSCSI) איומים: גישה לא מורשית ל-WWN, LUN spoofing. הגנות: Zoning (מי מדבר עם מי ב-fabric - מקביל ל-VLAN, LUN masking (איזה שרת רואה איזה נפח), VSAN (בידוד לוגי), אימות FC-SP / CHAP ל-iSCSI, והצפנת נתונים במנוחה. חשיבות: כל הנתונים הקריטיים של הארגון נמצאים שם.

6.13 Wi-Fi ו-Evil Twin

Evil Twin: התוקף מקים Access Point עם **אותו** SSID כמו הרשת החוקית, בעוצמה חזקה יותר. מכשירים מתחברים אליו אוטומטית (הם זוכרים את השם), והתוקף מבצע MITM - רואה הכול, מציג דף התחברות מזויף (captive portal) לגניבת סיסמה. הגנות: 802.1X WPA2/WPA3-Enterprise - המכשיר מאמת את השרת, לא רק להיפך, WIPS (Wireless IPS) שמזהה AP מתחזים, אימות הדדי.

בבגרות (שאלה 6)

"מהם מתכנני התקפת Evil Twin?" - **לשתול נקודת גישה זדונית, בעלת SSID זהה לנקודת גישה חוקית, לצורך גניבת מידע.**

6.14 מדריך פקודות מרוכז - פרק 6

פקודה	הגנה מפני
+ maximum + switchport port-security mac-address sticky + violation	MAC overflow
switchport + switchport mode access nonegotiate	VLAN hopping (DTP)
switchport trunk native vlan 999	double tagging
bpduguard + spanning-tree portfast ... default/enable	STP manipulation
/spanning-tree vlan N root primary priority	קיבוע root
limit rate + trust + ip dhcp snooping	DHCP spoofing/starvation
trust + ip arp inspection vlan	ARP poisoning
storm-control broadcast level	broadcast storm
monitor session	IDS ל-SPAN
switchport voice vlan	הפרדת VoIP
show, show port-security show ip dhcp snooping, spanning-tree binding	ורטיפקציה

6.15 תרגילים לתלמידים

תרגיל 1 - התאמת התקפה להגנה

חברו: (1) MAC flooding (2) rogue DHCP (3) ARP poisoning (4) כל ה-VLANים (5) מתג מזויף שמנסה להיות root. הגנות: DAI / port security / BPDU Guard+Root

Guard / switchport nonegotiate / DHCP snooping.

- switchport nonegotiate (access)→4 · DAI→3 · DHCP snooping→2 · port security→1
- BPDUGuard/Root Guard→5

תרגיל 2 - מי ה-root?

4 מתגים, SW1=32768, SW2=32768, SW3, SW4=32768. MAC, 4096=priority: SW1=32768, SW2=32768, SW3 - ה-priority נבדק ראשון והוא הנמוך. (4096) ה-MAC נבדק רק בתיקו. לו כולם היו 32768 - SW1 (MAC נמוך).

תרגיל 3 - ניתוח קונפיג

פורט f0/5 הוגדר: switchport port-security, maximum 1, violation shutdown. עובר חיבר אליו מתג קטן (switch) עם 3 מחשבים. מה יקרה, ומה ההודעה בלוג?
המתג הקטן יעביר מסגרות מ-MAC 3ים ⇒ בהפרה הראשונה (MAC שני) הפורט עובר ל-err-disabled ונכבה. בלוג: Fa0/5 ... psecure-violation ... PM-4-ERR_DISABLE: shut/no shut. שחזור:

תרגיל 4 - תכנון הקשחת מתג גישה

כתבו 8 פקודות הקשחה שתחילו על מתג גישה של קומה בבניין (24 פורטים למשתמשים, uplink אחד).
דוגמה: על פורטי הקצה: mode access, access vlan 10, nonegotiate, port-security max 2 sticky violation restrict, portfast, bpduguard enable, ip dhcp snooping (untrusted, limit uplink: mode trunk, nonegotiate, native vlan 999, allowed-rate), no cdp enable. ip dhcp snooping + vlan, ip arp vlan list, dhcp snooping trust, arp inspection trust. vlan 999 + shutdown. כיבוי פורטים לא בשימוש ל-inspection vlan, portfast bpduguard default.

6.16 שאלות בסגנון בגרות

שאלה 1

מה הדרך למנוע מתקפת MAC Table overflow במתג?

Port security על כל הפורטים שאינם trunk, עם הגבלת מספר כתובות MAC.

שאלה 2

איזו התקפת שכבה 2 אפשר לסכל על ידי השבתת פרוטוקול DTP? 1. DHCP spoofing 2. ARP spoofing 3. VLAN hopping 4. ARP poisoning
(switch spoofing). 3. VLAN hopping

שאלה 3

באיזו פקודה מפעילים BPDUGuard על כל פורטי ה-PortFast במתג?

spanning-tree portfast bpduguard default (במצב config גלובלי).

שאלה 4

STP פועל בשכבה ___ של OSI ומונע ___ על ידי ___.

(Data Link) 2 · לולאות (broadcast storm) · חסימת פורטים. (port blocking)

שאלה 5

מהי מתקפת Evil Twin ואיזו טכנולוגיית Wi-Fi מסייעת למנוע אותה?

נקודת גישה זדונית עם SSID זהה לחוקית לצורך MITM/גניבת מידע. מניעה: WPA2/WPA3-Enterprise עם 802.1X (אימות הדדי – המכשיר מוודא את זהות השרת) ו-WIPS.

שאלה 6

מהו תפקיד DHCP Snooping ואיזה מנגנון אבטחה נוסף מסתמך על הטבלה שהוא בונה?

חוסם הודעות שרת DHCP מפורטים לא-מהימנים (rogue server) ומגביל קצב Dynamic (starvation). ARP Inspection ו-IP Source Guard מסתמכים על טבלת ה-binding שלו.

6.17 (מעבדה 2 שעות) – הקשחת מתג ב-Packet Tracer

1. Port security: 2 מחשבים על פורט אחד (דרך hub/מתג קטן), maximum 1, violation shutdown. הוסיפו מחשב שני ⇒ err-disabled שחזרו עם shut/no shut והעלו ל-2 maximum.
2. BPDUGuard: הגדירו portfast+bpduguard על פורט קצה; חברו אליו מתג נוסף ⇒ err-disabled.
3. Root bridge: 3 מתגים בטבעת; הגדירו את המרכזי כ-root primary spanning-tree; show – ודאו מי root ואיזה פורט blocking.
4. DTP: הגדירו trunk מפורש + nonegotiate בין המתגים; פורטי קצה access + nonegotiate.
5. DHCP snooping: הפעילו, סמנו את פורט השרת trusted; הוסיפו "שרת DHCP" תוקף על פורט un-trusted וראו שההצעות שלו נחסמות.

בנק שאלות שתלמידים שואלים – ותשובות מוכנות

שאלות נפוצות בפרק אבטחת הרשת המקומית, עם תשובות מוכנות.

ש: "אם יש חומת אש בכניסה לרשת, למה בכלל צריך להגן על המתגים בפנים?"

ת: כי חומת האש מגנה מפני האינטרנט (מבחוץ), אבל אם תוקף כבר פינפ (חיבר מחשב לשקע, פרץ ל-Wi-Fi, השתלט על מחשב עובד) – הוא פועל בשכבה 2, מתחת לחומת האש. שם צריך DHCP, port security, ו-snooping וכו'.

ש: "הפורט עבר ל-err-disabled ונכבה. איך מחזירים אותו?"

ת: ידנית: shutdown ואז no shutdown על הממשק. אוטומטית אחרי זמן: errdisable recovery cause psecure-violation. show interfaces status err-disabled.

ש: "למה לולאה בין מתגים כל כך מסוכנת?"

ת: כי למסגרת בשכבה 2 TTL היא (בניגוד ל-IP) אם יש לולאה פיזית, הודעת broadcast מסתובבת לנצח ומשוכפלת בכל סיבוב – "סופת broadcast" שמשתקת את הרשת תוך שניות. STP מונע זאת על ידי חסימת פורט.

ש: "איך בוחרים את ה-root bridge ב-STP?"

ת: לפי ה-Bridge ID הנמוך ביותר = Priority (ברירת מחדל 32768 ואז כתובת MAC. אם ה-priority זהה אצל כולם – מנצח ה-MAC). שימו לב: ב-STP נמוך מנצח, ב-OSPF (פרק רשתות) גבוה מנצח – הפוך!

ש: "מה זה VLAN hopping ואיך DTP קשור?"

ת: DTP הוא פרוטוקול שמנהל אוטומטית אם קישור יהיה trunk. תוקף יכול להתחזות למתג, "לשכנע" את הפורט להפוך ל-trunk, ואז לקבל גישה לכל ה-VLANים. הפתרון: לכבות DTP (switchport nonegotiate) ולהגדיר פורטי קצה כ-access מפורש.

ש: "מה זה rogue DHCP ולמה זה מסוכן?"

ת: תוקף מקים שרת DHCP משלו שעונה מהר יותר מהאמיתי, ומחלק לקורבנות default gateway ו-DNS ולש – וכך כל התעבורה שלהם עוברת דרכו. (MITM) ההגנה: DHCP snooping, שמסמן פורטים "מהימנים" וחוסם הצעות משרתים לא מורשים.

ש: "מה זה Evil Twin ואיך מתגוננים?"

ת: נקודת גישה זדונית עם (SSID) תשר שש ותוא כמו החוקית, בעוצמה חזקה יותר – מכשירים מתחברים אליה

אוטומטית והתוקף מבצע MITM. הגנה: WPA2/WPA3-Enterprise עם 802.1X (אימות הדדי - המכשיר מוודא שהשרת אמיתי) ו-WIPS.

ש: "מה ההבדל בין port security ל-802.1X?"

ת: port security מגביל MAC תובות וליא/המכ מותרות בפורט (הגנה מפני (802.1X MAC flooding) דורש רישכמ/שמתשמ תומיא מלא מול שרת RADIUS לפני שנותנים גישה. 802.1X חזק בהרבה אך דורש תשתית שרת.

מילון מונחים - הגדרות

הגדרות תמציתיות של המונחים המרכזיים בפרק. שימושי גם כדף עזר לבחינה.

מונח	הגדרה
שכבה 2 (Data Link)	שכבת הקישור; עובדת בכתובות MAC, מתגים ומסגרות. (frames)
מתג (Switch)	מכשיר שמחבר מכשירים ברשת מקומית ולומד כתובות MAC לכל פורט.
טבלת MAC (CAM)	טבלה במתג הממפה כתובת MAC לפורט; מוגבלת בגודלה.
MAC flooding / overflow	הצפת המתג בכתובות MAC מזויפות עד שהוא משדר לכולם (כמו hub).
Port Security	הגבלת מספר/זהות כתובות MAC בפורט; הגנה מפני MAC flooding.
violation (protect/restrict/shutdown)	תגובת port security להפרה: התעלמות, התראה, או כיבוי הפורט. (err-disabled)
VLAN	רשת לוגית מבודדת בתוך מתג פיזי; מעבר בין VLANים דורש ניתוב.
Trunk (802.1Q)	קישור הנושא כמה VLANים בין מתגים, עם תיוג של מספר ה-VLAN.
DTP	פרוטוקול שמנהל אוטומטית trunk; יש לכבותו כדי למנוע VLAN hopping.
VLAN hopping	קבלת גישה ל-VLANים אחרים בניצול DTP או תיוג כפול.
STP (Spanning Tree)	פרוטוקול שמונע לולאות בשכבה 2 על ידי חסימת פורטים.
Root Bridge	המתג המרכזי ב-STP; נבחר לפי Bridge ID הנמוך (priority), ואז MAC.
BPDU Guard	מכבה פורט קצה שמקבל BPDU (חובר אליו מתג/תוקף).
DHCP starvation / spoofing	דלדול כתובות ה-DHCP, או הקמת שרת DHCP מזויף ל-MITM.
DHCP Snooping	סימון פורטים מהימנים וחסימת הצעות DHCP מפורטים לא מורשים.
ARP spoofing / poisoning	זיוף הודעות ARP כדי להפנות תעבורה לתוקף (MITM).
DAI (Dynamic ARP Inspection)	בדיקת הודעות ARP מול טבלת ה-DHCP snooping; חוסם זיופים.
Storm Control	הגבלת אחוז תעבורת broadcast/multicast בפורט; מונע סופות.
NAC	בקרת גישה שבודקת 'בריאות' מכשיר לפני מתן גישה (מבוסס 802.1X).
Evil Twin	נקודת גישה זדונית עם SSID זהה לחוקית, ל-MITM ברשת אלחוטית.